

Bài 2. Phân tích tĩnh mã độc cơ bản

Báo cáo

A. Lý thuyết

1. Phân tích tĩnh (Static Analysis)

- **Định nghĩa:** Là việc phân tích chương trình mà không thực thi nó, thông qua source code/bytecode/binary code.
- Mục đích:
 - Đưa ra đánh giá rủi ro mà không cần chạy file, trong trường hợp không có sandbox an toàn.
- Ưu điểm:
 - An toàn, tiện lợi vì không cần chạy file có thể là mã độc.
 - Khảo sát được tất cả các khả năng thực thi và giá trị của các biến.
- Hạn chế:
 - Không quan sát được sự thực thi của file, do đó có thể không phân tích/phát hiện được các lỗi hổng/sự thực thi tinh vi, edge-case.
- So sánh với Dynamic Analysis: Dynamic analysis cần chạy file, còn static analysis không cần.

2. Nghiên cứu các công cụ

Công cụ	Chức năng chính	Dữ liệu có thể trích xuất	Ví dụ thông tin có giá trị trong điều tra malware
exeinfope	Nhận dạng trình biên dịch, kỹ thuật đóng gói/rối mã.	- Loại file executable - Section, header, resource table, import/export table - Packer, cryptors - Icon - Checksum	- Một app bị pack bởi UPX: "Big sec. 02 [UPX1] , try upx.exe -d option (min. 3.91 UPX required !!!)"
PEStudio	Phân tích tĩnh toàn diện file PE, tự động flag các dấu hiệu bất thường.	- Entropy, imphash - Resource ... (chi tiết)	- "virustotal (score > 48/71)" - "imports (flag > 22)" - "libraries (flag > 1)"
Strings	Tìm kiếm nhanh chuỗi ký tự đọc được có độ dài	UNICODE/ASCII static strings: API calls, tên miền, chữ	- Dấu hiệu C2: " qweb2.com/888/index2.php " - Chữ ký của packer: "UPX0",

	>=4 ký tự.	ký của packer...	".aspack" - Chuỗi base64 - Registry key: "Software\Microsoft\Windows\CurrentVersion\Run"
CFF Explorer	Xem và chỉnh sửa nâng cao cấu trúc file PE.	- DOS header, NT headers, optional header. - Section headers - Data directories	"Import Directory: WINHTTP.dll (WinHttpCrackUrl, WinHttpReceiveResponse, WinHttpOpen)"
FLOSS	Phát hiện, giải mã các chuỗi ký tự bị làm rối/mã hóa hoặc Stack strings (chuỗi được tạo bằng cách đẩy từng ký tự một vào stack).	- Static strings - Stack strings - Tight strings (dạng đặc biệt của stack string) - Decoded strings	- "FLOSS TIGHT STRINGS: (Function Function Offset Frame Offset String): bcrypt.dll"
capa	Phát hiện tactic, technique, chức năng của malware.	- File signature - ATT&CK Tactic, Technique - Capability - Namespace	"ATT&CK Tactic ATT&CK Technique: DEFENSE EVASION Obfuscated Files or Information"
Detect-It-Easy (DIE)	Phân tích dựa trên bộ signature có thể tùy chỉnh được, và phân tích heuristic.	- OS, Compiler, Linker, Language - Protection, Packer - Overlay	- "(Heur) Protection: Generic [Section #0 ("UPX0") has RWX + IAT directory empty]" - "Packer: UPX (4.24) [NRV, brute]"

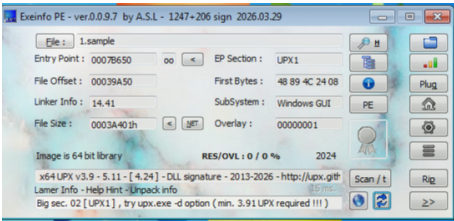
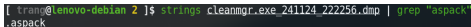
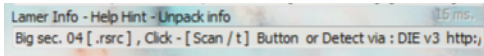
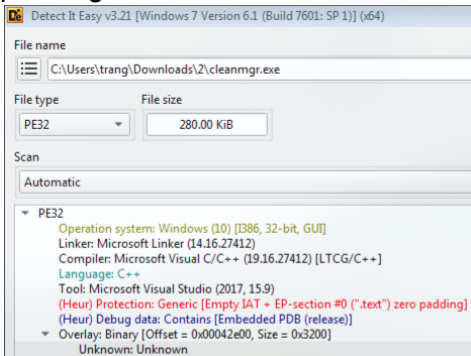
3. Dữ liệu nào quan trọng cần quan tâm khi phân tích tĩnh PE?

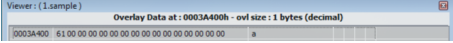
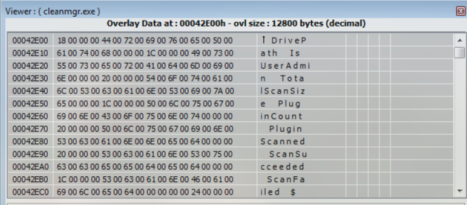
Các dữ liệu quan trọng khi phân tích tĩnh PE:

- URL -> khả năng Command and Control.
- IAT - API calls.
- Imphash: fingerprinting file dựa trên import table -> theo dõi các biến thể của cùng 1 chủng mã độc.
- Strings: có thể bao gồm cả các URL, Registry... khả nghi.
- Entropy: cho biết dấu hiệu có packing/obfuscation.

B. Thực hành

1. Thực hiện phân tích tĩnh các mẫu được cung cấp

File	1.sample	cleanmgr.exe_241124_222256.dmp
Tên file	1.sample	cleanmgr.exe_241124_222256.dmp / cleanmgr.exe
Kích thước	234 Kilobyte	66 Megabyte / 280 Kilobyte
Hash	(md5) 2ac84971b08781272ef591ca02b8d98f (sha256) a5ef58631cc8fa9d39cac9ba9989dc29 42ccabe011da2ca098d1f5ec9250c772	(md5) f13a9fbd8e30fc86f4cd685d412e9be 0 (sha256) b1548b6f11b5137b364878176a8ee1 0d5cc398e530eab306439efb7c5a36 13fa / (md5) 5e6c46be33701698b70d52c29d5c3 6c6 (sha256) 5e9f01698c62f95ab392ec03ecebda f41395fa0cc202d63ae6aee4ea8e4de 201
Kiểu file ('file' command)	PE32+ executable for MS Windows 6.00 (DLL), x86-64, 3 sections	Mini DuMP crash report, 17 streams, Sun Nov 24 15:22:57 2024, 0x461826 type / PE32 executable for MS Windows 10.00 (GUI), Intel i386, 5 sections
Packer / Obfuscation	- Packer: UPX3.91+  - Obfuscation: <pre> encode data using XOR namespace data-manipulation/encoding/xor author moritz.raabe@mandiant.com scope basic block att&ck Defense Evasion:Obfuscated Files or Information [T1027] mbc Defense Evasion:Obfuscated Files or Information:Encoding-Standard Algorithm [E1027.m02], Data:Encode Data:XOR [C0026.002] basic block @ 0x180012901 in function 0x180026554 and: characteristic: light loop @ 0x180012901 characteristic: loop @ 0x180012905 not: = filter for potential false positives or: or: = unsigned bitwise negation operation (~) number: 0xffffffff = bitwise negation for unsigned 32 bits number: 0xffffffffffffffff = bitwise negation for unsigned 64 bits or: = signed bitwise negation operation (~) number: 0xffffffff = bitwise negation for signed 32 bits number: 0xffffffffffffffff = bitwise negation for signed 64 bits or: = Magic constants used in the implementation of strings functions. number: 0x7efefeff = optimized string constant for 32 bits number: 0x81010101 = -0x1010101 = -0x7efefeff number: 0x81010100 = -0x7efefeff number: 0x7efefeff = optimized string constant for 64 bits number: 0x8101010101010101 = -0x10101010101010101 = -0x7efefeffffffff number: 0x8101010101010100 = -0x7efefeffffffff hash data using fnv namespace data-manipulation/hashing/fnv author moritz.raabe@mandiant.com, @re_fox, michael.hunhoff@mandiant.com scope function mbc Data:Non-Cryptographic Hash:Fnv [C0030.005] references https://en.wikipedia.org/wiki/Fowler-Noll-Vo (FNV) hash function, https://create.stephan-brumme.com/fnv-hash/, http://isthe.com/chongo/tech/comp/fnv/, https://create.stephan-brumme.com/fnv-hash/ description can be any Fowler-Noll-Vo (FNV) hash variant, including FNV-1, FNV-1a, FNV-0 function @ 0x180026554 and: </pre>	- Packer: ASPack  - Obfuscation: không có. - Section 4 (resource) lớn bất thường.  - Protection khác: .text section zero padding. 

Overlay	 (1 byte)	 (12800 bytes) -> dữ liệu trong overlay của file này là dữ liệu benign của chương trình gốc cleanmgr.exe, không khả nghi.
Các API đáng ngờ	VirtualProtect (thường dùng trong Process Injection); WinHttpOpen (C2); WinHttpRequest;	(Process Injection) OpenProcess, VirtualAllocEx, WriteProcessMemory, SetThreadContext, CreateRemoteThread; (Encryption) CryptAcquireContextW, CryptEncrypt, CryptDecrypt, DecryptFileW, EncryptFileW; (Privilege Escalation) AdjustTokenPrivileges, SetWindowsHookExW; (Defense Evasion) IsDebuggerPresent; (Persistence) HttpSendRequestExW, RegSetValueExW (Execution) ShellExecuteExW, CreateMutexExW, CreateFileMappingW, LoadLibraryExW, EnumProcesses;
Strings đáng ngờ	KERNEL32.DLL WINHTTP.DLL GetProcAddress LoadLibrary VirtualProtect (flagged bởi PEStudio)	.aspack; sqlite3_vmprintf; winhttp.dll; WinHttp*; HTTP/65535.65535;

	WinHttpOpen DllDo.dll RegisterModule "?qweb2.com/888/index2.php"; (có thể là dấu hiệu của C2) C:\Users\aa\source\repos\DllDo\x64\Release\DllDo.pdb	http://air.thaovanhoakh.com:53/search.jsp?referer=QTJBMT0zQUI4&kw=BWkrJw==&psid=Zh1KFg==;
Dấu hiệu persistence		Gọi đến các API: HttpSendRequestExW, RegSetValueExW.

2. Đưa ra nhận định, các dấu hiệu cho thấy các file trên có khả năng là malware

- 1.sample:
 - Dấu hiệu tổng quát:
 - Bị packed, obfuscated.
 - Overlay đáng ngờ: chỉ 1 byte.
 - Có gọi các API đáng ngờ. File gốc chỉ là 1 .DLL mà lại gọi WinHttpOpen và VirtualProtect.
 - Có truy vấn '?qweb2.com/888/index2.php'.
 - Có gọi RegisterModule - API cần thiết để mọi HTTP module hoạt động.
 - Capability: persist via IIS module.
 - Nhận định:
 - File này có thể là một IIS HTTP Module malware, thuộc loại backdoor (vì có gọi đến RegisterModule đảm bảo persistence mỗi lần boot) hoặc downloader.
- cleanmgr.exe:
 - Dấu hiệu tổng quát:
 - Bị packed.
 - Xuất hiện sqlite3_vmprintf trong 1 ứng dụng đáng lẽ được dùng để dọn dẹp file.
 - Sử dụng port 53 để [bypass firewall](#), thiết lập kết nối C2 đến server air.thaovanhoakh.com.
 - Xuất hiện HTTP header dị dạng có thể do actor tự chế ra.

- Sử dụng rất nhiều API calls khả nghi.
- Có dấu hiệu persistence.
- Nhận định:
 - File cleanmgr.exe đó là 1 mã độc, có thể thuộc loại stealer vì có nhắm đến cơ sở dữ liệu SQL của trình duyệt. Việc gọi đến các API liên quan tới encryption có thể để giải mã creds trong cơ sở dữ liệu nạn nhân.